

Response-Rescaling Fresh-Message Forgeries for SQIsignTriangle

A Conditional One-Signature Transformation Across All Four Submitted Parameter Sets

Martin Feussner

Selmer Center, University of Bergen

`martin.feussner@uib.no`

27 September 2026

Provenance and review status. The attack was independently found by an AI system, OpenAI Codex using Daybreak Blue at maximum reasoning effort, without a human first proposing this specific attack. The AI produced the derivation, implementation, experiments, and initial manuscript. At the date above, no human cryptanalyst has independently verified the argument, implementation, measurements, or novelty assessment. This preliminary disclosure is provided for human review and reproduction.

Abstract

SQIsignTriangle represents a response by an auxiliary curve, an auxiliary 2^e -torsion basis, and an odd integer q . Verification reconstructs a two-dimensional kernel generated by

$$([q]P_{\text{pk}}, P_{\text{aux}}) \quad \text{and} \quad ([q]Q_{\text{pk}}, Q_{\text{aux}}),$$

recovers two possible commitment curves, and accepts when $q \equiv c_2 \pmod{c_1}$ for the hash challenge of either curve and the message.

This response has an unchecked scaling symmetry. For any odd unit u modulo 2^e , replacing q by $q' \equiv uq \pmod{2^e}$ and multiplying the auxiliary basis by u multiplies both kernel generators by the same unit. The same kernel gives an isomorphic quotient whose two codomain factors have the same unordered isomorphism classes, and hence the same j -invariants. Starting from one valid signature, an attacker can select an odd e -bit integer q' satisfying a fresh-message hash congruence, set $u = q'q^{-1} \pmod{2^e}$, and scale the four serialized auxiliary-basis coefficients. This one-signature transformation is proved when the selected target challenge satisfies the public sufficient condition $2^{e-1} > 2c_1$. It uses one signing query and requires neither secret information nor a hash weakness.

We reproduced the attack against the unmodified submitted reference verifier on three independently generated keys for each of the 128-, 160-, 256-, and 512-bit parameter sets. The sufficient condition held in every trial, one signing query was used per trial, and all 12 fresh-message forgeries were accepted. The slowest forgery computation took 4.33 seconds on a four-core Intel Core i5-6500, and the other three levels took below 0.7 seconds. The submission provides no lower bound or lower-tail distribution for honest response lengths, so we do not claim that the condition is guaranteed or holds with overwhelming probability. If it fails, the general attack repeats signing queries until it obtains an eligible response; this report does not bound the expected number of queries.

1 Introduction

SQIsignTriangle is an isogeny-based signature submission to the Next-generation Commercial Cryptographic Algorithms Program (NGCC). It follows a Fiat–Shamir transformation of a

three-move protocol and replaces the usual fixed challenge isogeny with a modular degree condition

$$q \equiv c_2 \pmod{c_1}. \quad (1)$$

The response is represented through Kani’s lemma by a 2^e -isogeny from a product $E_{\text{pk}} \times E_{\text{aux}}$, where $e = \text{bits}(q)$. The verifier reconstructs its kernel from the public basis, the integer q , and an auxiliary basis contained in the signature [1].

The kernel representation is homogeneous: multiplying every kernel generator by a unit modulo 2^e does not change the generated subgroup. In the submitted response format, an attacker can perform exactly this scaling while changing the integer used in Equation (1). The geometric part of verification continues to recover the original commitment, whereas the replacement integer can be chosen to satisfy a fresh-message challenge whenever the public response-size condition below holds.

The attack is especially direct:

- it uses one ordinary signature whenever the public response-size condition holds, and no secret-key information;
- it targets the specified verification equation and succeeds without malformed inputs, undefined behavior, or a weak hash function;
- its only expensive step is one public verifier-style isogeny-chain computation; and
- the same transformation applies to all four submitted parameter sets.

This is stronger than ordinary signature malleability. The output verifies on a message that was never submitted to the signing oracle. In every reported control, the genuine signature rejected the target message and the transformed signature rejected the source message. Those two rejection observations are experimental controls, not consequences required by the algebraic theorem.

Related work and novelty. The NGCC tracker credits Tako Boris Fouotsa with two earlier SQIsignTriangle findings [2]. Finding **sign-27-3** is already a fresh-message forgery: it keeps a known valid response fixed and searches over candidate fresh messages until the resulting challenge satisfies $q \equiv c_2 \pmod{c_1}$. Because the relevant challenge value has $\lambda/2$ bits, this requires approximately $2^{\lambda/2}$ classical hash trials. Finding **sign-27-4** observes that distinct modular challenges can share an identical response, invalidating the special-soundness argument.

The present attack is therefore not the first forgery result for SQIsignTriangle. It exploits a different symmetry in the same modular-challenge weakness. Instead of fixing the response and searching for a compatible message, it fixes an arbitrary fresh message, changes q to meet that message’s challenge, and rescales the auxiliary basis so that the verification kernel is preserved. Subject to the public response-size condition, this removes the $2^{\lambda/2}$ hash search and reduces the work to a verifier-style computation plus modular arithmetic. We characterize the result as a substantially faster, practically demonstrated exploitation and a practical strengthening of the same modular-challenge weakness, independently derived through response rescaling: all four submitted parameter sets were forged within seconds in our experiments. A public discussion of malleability in standard SQIsign concerns strong unforgeability rather than this fresh-message mechanism [3].

2 The verification equation

We state only the parts of SQIsignTriangle needed for the attack. Let the field parameter satisfy $p = c \cdot 2^f - 1$. A public key contains a curve E_{pk} and a hint from which the verifier

reconstructs a basis $(P_{\text{pk}}^{(f)}, Q_{\text{pk}}^{(f)})$ of the full 2^f -torsion. A signature is

$$\sigma = (E_{\text{aux}}, P_{\text{aux}}, Q_{\text{aux}}, q), \quad (2)$$

where q is positive and odd and

$$e = \text{bits}(q). \quad (3)$$

The submitted verifier also checks $3 \leq e \leq f$ and verifies that the public and auxiliary pairs have exact order 2^e .

Define the cofactor-reduced public basis

$$\bar{P}_{\text{pk}} = [2^{f-e}]P_{\text{pk}}^{(f)}, \quad \bar{Q}_{\text{pk}} = [2^{f-e}]Q_{\text{pk}}^{(f)}.$$

Scalar multiplication commutes with the cofactor reduction used in the implementation. The verifier constructs the subgroup

$$K_\sigma = \langle ([q]\bar{P}_{\text{pk}}, P_{\text{aux}}), ([q]\bar{Q}_{\text{pk}}, Q_{\text{aux}}) \rangle \subseteq (E_{\text{pk}} \times E_{\text{aux}})[2^e]. \quad (4)$$

It evaluates the corresponding two-dimensional isogeny chain and obtains a split codomain $F_1 \times F_2$. For $i \in \{1, 2\}$ it derives

$$(c_{1,i}, c_{2,i}) = \mathcal{H}(j(E_{\text{pk}}), j(F_i), M). \quad (5)$$

It accepts if, for either component,

$$q \equiv c_{2,i} \pmod{c_{1,i}}. \quad (6)$$

The submitted implementation tries F_1 first and then F_2 . Thus no component label needs to be predicted by the attacker.

There is a presentation inconsistency in Algorithm 4.3 of the specification: its pseudocode hashes an as-yet undefined E_{com} before reconstructing $F_1 \times F_2$. Section 4.4 nevertheless states the intended relation: the kernel in Equation (4) is evaluated, one recovered factor is the commitment, and the response must meet the modular challenge. The reference verifier resolves the ordering issue by reconstructing the quotient first and then evaluating Equation (6) for both factors. Our algebraic argument targets this intended specified relation. Claims about byte decoding, branch order, and measured acceptance refer separately to the submitted implementation.

2.1 Serialized auxiliary bases

For each submitted level, the signature stores E_{aux} , four little-endian coefficients (r_1, r_2, s_1, s_2) , and q . Let $(P_{\text{aux}}^{(f)}, Q_{\text{aux}}^{(f)})$ be the deterministic full basis used by the decoder. Up to the implementation's equivalent order of operations, the decoded points are

$$P_{\text{aux}} = [2^{f-e}]([r_1]P_{\text{aux}}^{(f)} + [r_2]Q_{\text{aux}}^{(f)}), \quad (7)$$

$$Q_{\text{aux}} = [2^{f-e}]([s_1]P_{\text{aux}}^{(f)} + [s_2]Q_{\text{aux}}^{(f)}). \quad (8)$$

Consequently, multiplying all four coefficients by the same value modulo 2^e multiplies both decoded points by that value. The differences introduced by reduction modulo 2^e vanish after multiplication by 2^{f-e} .

The submitted byte lengths are shown in Table 1. They agree between the technical specification and the reference API.

Table 1: Submitted SQIsignTriangle parameter and encoding sizes.

Instance	λ	f	Public key bytes	Signature bytes	Coefficient/ q bytes
lv11	128	248	65	204	28
lv12	160	309	81	255	35
lv15	256	500	129	408	56
lv16	512	1016	257	816	112

3 The response-rescaling symmetry

Write $R_e = \mathbb{Z}/2^e\mathbb{Z}$. Since the verifier requires q to be odd, q is a unit in R_e .

Lemma 1 (Kernel invariance). *Let q' be any odd integer with $\text{bits}(q') = e$, and set*

$$u = q'q^{-1} \pmod{2^e}. \quad (9)$$

Replace the auxiliary basis by

$$(P'_{\text{aux}}, Q'_{\text{aux}}) = ([u]P_{\text{aux}}, [u]Q_{\text{aux}}).$$

Then the kernel reconstructed from $(q', P'_{\text{aux}}, Q'_{\text{aux}})$ is exactly K_σ .

Proof. Because $q' \equiv uq \pmod{2^e}$ and all points in Equation (4) are in the 2^e -torsion, the two new generators are

$$\begin{aligned} ([q']\bar{P}_{\text{pk}}, P'_{\text{aux}}) &= ([uq]\bar{P}_{\text{pk}}, [u]P_{\text{aux}}) = [u]([q]\bar{P}_{\text{pk}}, P_{\text{aux}}), \\ ([q']\bar{Q}_{\text{pk}}, Q'_{\text{aux}}) &= ([uq]\bar{Q}_{\text{pk}}, [u]Q_{\text{aux}}) = [u]([q]\bar{Q}_{\text{pk}}, Q_{\text{aux}}). \end{aligned}$$

Both q and q' are odd, so u is odd and hence a unit in R_e . Multiplication by u is an automorphism of the 2^e -torsion. The scaled generators therefore span the same subgroup. The exact-order checks also continue to hold. $\square$

Corollary 2 (Quotient and factor invariance). *The original and rescaled signatures have the same kernel and therefore define isomorphic quotients. Whenever the quotient is represented as a split product, the two codomain factors have the same unordered isomorphism classes. In particular, the unordered pair of j -invariants used in Equation (5) is unchanged.*

Proof. The source product is unchanged and Lemma 1 gives equality of the finite kernel subgroups. The quotient by that subgroup is consequently unique up to isomorphism. Its decomposition yields the same factor isomorphism classes up to ordering, so their j -invariants agree. $\square$

This is a property of the mathematical response representation. It does not depend on lenient parsing or on a particular sequence of formulas inside the reference code.

4 Fresh-message forgery

Let M^* be any message distinct from the signing query. The attacker first runs the public part of verification on a valid signature to recover F_1, F_2 . Select a component F_i and compute the target challenge (c_1, c_2) from Equation (5) using M^* .

The attacker needs an odd integer in the interval

$$2^{e-1} \leq q' < 2^e, \quad q' \equiv c_2 \pmod{c_1}. \quad (10)$$

The challenge modulus c_1 is an odd prime. A direct construction is

$$k_0 = \left\lceil \frac{2^{e-1} - c_2}{c_1} \right\rceil, \quad (11)$$

$$q_0 = c_2 + k_0 c_1. \quad (12)$$

Use $q' = q_0$ if it is odd and $q' = q_0 + c_1$ otherwise. The exact public eligibility test is whether one of these odd representatives lies in the e -bit interval. A simple sufficient condition is

$$2^{e-1} > 2c_1 \quad (13)$$

because it leaves room for two consecutive representatives. In the submitted sets, c_1 has at most 64, 80, 128, and 256 bits, respectively. Our genuine signatures had e between 219 and 895, depending on the level, so the number of available representatives is enormous.

Equation (13) is not guaranteed by honest signing in either the specification or the submitted code. The specification's discussion of `EquivalentSpecialIdeal` gives heuristic typical-size reasoning and an upper-bound argument for its lattice output, but no lower bound or lower-tail probability for q . The signer computes $e = \text{bits}(q)$ and rejects responses that are even or exceed the torsion and encoding limits; it does not reject a response merely because e is small relative to c_1 . Consequently, the available material does not justify saying that Equation (13) holds with overwhelming probability. Its satisfaction in the experiments below is evidence about those tested executions only.

After finding q' , compute u by Equation (9). Keep E_{aux} unchanged, replace the four serialized basis coefficients by

$$(r'_1, r'_2, s'_1, s'_2) = u(r_1, r_2, s_1, s_2) \pmod{2^e}, \quad (14)$$

and replace q by q' . Because q' has the same bit length, the decoder uses the same cofactor and all transformed coefficients fit the submitted encoding.

Theorem 3 (Conditional one-signature forgery). *Suppose a valid `SQIsignTriangle` signature has response bit length e and the challenge of a selected recovered factor on M^* satisfies Equation (13). The transformation in Equations (10)–(14) produces a valid signature on the chosen target message M^* under the verification relation in Equations (4)–(6).*

Proof. The constructed q' is positive, odd, has bit length e , and satisfies the target congruence. Lemma 1 shows that the verifier reconstructs the same kernel. It therefore obtains the same codomain factors, including the selected F_i . When it hashes F_i with M^* , it obtains the public values (c_1, c_2) used to construct q' , so $q' \equiv c_2 \pmod{c_1}$. All range, curve, basis-order, isogeny-chain, and congruence checks pass. $\square$

The theorem permits either recovered factor to be selected, provided its own target challenge meets Equation (13). This is algebraic rather than an inference from the experiments: quotient invariance preserves both factor j -invariants, and Equation (6) is a disjunction over the two branches. The separate tests below exercise this conclusion in the submitted implementation.

Attack algorithm. The complete repeat-until-eligible adversary is as follows.

1. Choose a target message M^* and request a signature σ on a distinct source message.
2. Parse q , compute $e = \text{bits}(q)$, and execute the public isogeny-chain portion of verification to obtain F_1, F_2 .
3. Hash each recovered factor with M^* . If neither branch has an odd e -bit representative in its target residue class, discard this response and repeat from Step 1 with another source signing query. Equation (13) is a sufficient public test for a branch.

4. Construct q' by Equation (10), compute $u = q'q^{-1} \bmod 2^e$, and apply Equation (14).
5. Output the unchanged auxiliary curve, the four transformed coefficients, and q' .

For an eligible first response, this uses exactly one signing query. Otherwise it makes further queries. Because the honest-response lower tail is not specified or proved, we give no theorem for the expected query count. The source message can also be used to identify an originally accepting factor by testing Equation (6), although the submitted verifier’s two target branches make that identification unnecessary.

4.1 EUF-CMA interpretation

In the EUF-CMA experiment, the adversary may request signatures on messages of its choice and wins by producing a valid signature on a message absent from its query set [5]. The algorithm above outputs a signature on the unqueried M^* and is therefore a fresh-message forgery rather than a second encoding for a queried message. Theorem 3 proves one-query success only when the first response meets the stated public condition. A formal asymptotic EUF-CMA advantage for the repeat-until-eligible adversary would additionally require a lower bound on the probability of that event; the submission does not provide one, and this paper does not infer one from 12 trials. The attack does not recover the secret key.

5 Experimental validation

We built the portable reference implementation from the archived submission and called its unmodified signature-verification API. The experiment used GCC 13.3.0 on Ubuntu 24.04, with an Intel Core i5-6500 at 3.20 GHz and four physical cores. Only one core was needed by each attack run.

For every parameter set we generated three fresh key pairs. Before each key generation, the harness DRNG was initialized with a distinct 48-byte seed obtained as

`SHAKE25648(SQIsignTriangle level L, key I),`

where $L \in \{1, 2, 5, 6\}$ and $I \in \{0, 1, 2\}$. For each key we signed the literal source message

`SQIsignTriangle source, level L, key I`

and forged the distinct target

`SQIsignTriangle fresh target, level L, key I.`

In each trial we observed all four of the following controls:

1. the genuine signature was accepted on the source message;
2. the genuine signature was rejected on the target message;
3. the forged signature was accepted on the target message; and
4. the forged signature was rejected on the source message.

The theorem requires the third observation under its stated condition. It does not require the second or fourth: a congruence coincidence could make a genuine signature accept another message or a transformed signature accept the source. Those two rejections report what the reference verifier did in these experiments. All 12 trials passed. Table 2 reports the observed

Table 2: End-to-end fresh-message forgery results on three independent keys per submitted level.

Instance	Accepted	Observed e	Forgery time range	Maximum
lvl1	3/3	219–221	0.033–0.046 s	0.046 s
lvl2	3/3	275–276	0.023–0.051 s	0.051 s
lvl5	3/3	442–443	0.233–0.690 s	0.690 s
lvl6	3/3	893–895	0.401–4.329 s	4.329 s

response bit lengths and the time for public codomain reconstruction, target challenge derivation, modular rescaling, and serialization. It excludes the signing oracle’s work and a final verification call.

As a separate component-branch check, on one key at each level we deliberately constructed a second forgery using the codomain factor that did not satisfy the original source-message congruence. All four of those signatures were also accepted on their target messages. This experimentally exercises both branches of the submitted verifier on those four instances. The general factor-choice statement used by the theorem follows separately from quotient invariance and the disjunctive relation in Equation (6), with the response-size condition applied to the chosen branch.

For a deterministic level-1 check, we also seeded the DRNG with the 48 bytes `00,01,...,2f` and signed `SQIsignTriangle` source message. The signature had $e = 220$. For the target `SQIsignTriangle` fresh target message, the second recovered factor gave

$$c_1 = 18337881540236675959, \quad c_2 = 5510551482462846558.$$

The construction produced an odd 220-bit q' in that residue class. In this test, the reference API accepted the transformed 204-byte signature on the target and rejected it on the source; it accepted the genuine signature on the source and rejected it on the target.

6 Root cause and scope

The response is checked in two logically separate ways:

1. the kernel determines a quotient whose factor must reproduce the commitment curve; and
2. the integer q must satisfy a short modular challenge relation.

The verifier assumes these checks refer to one fixed response isogeny. In fact, the kernel is invariant under simultaneous multiplication of its public and auxiliary coordinates by a unit, while the integer representative q changes. This lets the attacker retain the commitment while selecting the integer representative after seeing the target challenge.

The attack is independent of the submitted hash implementation: it only evaluates the public hash and uses its output. It also survives strict and canonical byte decoding, because every transformed coefficient and q' is within its prescribed range. The previously reported assertion failure on an all-zero signature is unrelated [2].

The proof of EUF-CMA security must account for the full unit orbit of a response. Treating q as the norm selected by the honest `EquivalentSpecialIdeal` algorithm is insufficient for adversarial verification, because the verifier does not establish that provenance. The same symmetry follows from the kernel and modular challenge stated in Section 4.4 and Algorithm 4.3 of the specification. We therefore describe the point-level vulnerability as design-level with respect to the intended verification relation. Algorithm 4.3 itself has the ordering ambiguity noted above; the claims that the verifier hashes both factors in sequence and that coefficient

rescaling realizes point rescaling are supported by the submitted implementation and encoding description. The experiments establish that the reference code implements the vulnerable relation; the argument does not rely on a wrapper defect, malformed parsing, or undefined behavior.

Repair direction. A repair must cryptographically bind the scalar representative used in the challenge check to the geometric response. Merely checking point orders, requiring canonical byte strings, or changing the hash function does not remove the unit orbit. Possible redesigns include a publicly verifiable canonical representative for the entire response orbit, a proof that binds the claimed norm to the represented response, or a challenge that fixes the full scalar rather than only its residue modulo a much smaller prime. Each option changes the protocol and requires a new correctness and security analysis; adding q to the existing pre-response hash would introduce a circular dependency and is not by itself a complete fix.

7 Conclusion

SQIsignTriangle’s compact two-dimensional response admits a public unit rescaling that leaves its verification kernel unchanged. The modular-degree challenge is applied to a scalar representative rather than to the invariant kernel, so an eligible representative can be retargeted to a fresh-message hash challenge. One genuine signature was sufficient in every reported trial, the work was comparable to a verification, and the attack was reproduced on all four submitted parameter sets. The proof of one-query success is conditional on Equation (13); neither a universal guarantee nor an overwhelming-probability bound for honest responses is claimed. The result exhibits concrete fresh-message forgeries and a design-level verification symmetry, while a fully quantified asymptotic EUF-CMA advantage would require an honest-response eligibility bound absent from the submission.

References

- [1] Wei Yu, Bin Wang, Tingyu Xing, Wenbiao Chen, Jiaxuan Qu, Xiuyu Qiu, Song Tian, and Kunpeng Wang. *SQIsignTriangle: Short Quaternion and Isogeny Signature with a Triangle-shaped Framework*. NGCC submission specification, 2026. <https://www.niccs.org.cn/niccs/Proposal/Public-Key%20Cryptographic%20Algorithms/Round%201%20candidates/SQIsignTriangle.zip>.
- [2] NGCC Security Project. *SQIsignTriangle (sign-27)*. Public issue tracker, including findings sign-27-3 and sign-27-4 credited there to Tako Boris Fouotsa; accessed 27 September 2026. <https://ngcc.dev/reports/sign-27.html>.
- [3] Dustin Ray. *Towards SUF-CMA SQIsign*. Public issue discussion, June 2026. <https://github.com/anchorageoss/sqisign-rs/issues/19>.
- [4] Amos Fiat and Adi Shamir. How to prove yourself: Practical solutions to identification and signature problems. In *Advances in Cryptology – CRYPTO ’86*, pages 186–194. Springer, 1987.
- [5] Shafi Goldwasser, Silvio Micali, and Ronald L. Rivest. A digital signature scheme secure against adaptive chosen-message attacks. *SIAM Journal on Computing*, 17(2):281–308, 1988.